



1b. Defence Overview

Jin Hong

jin.hong@uwa.edu.au

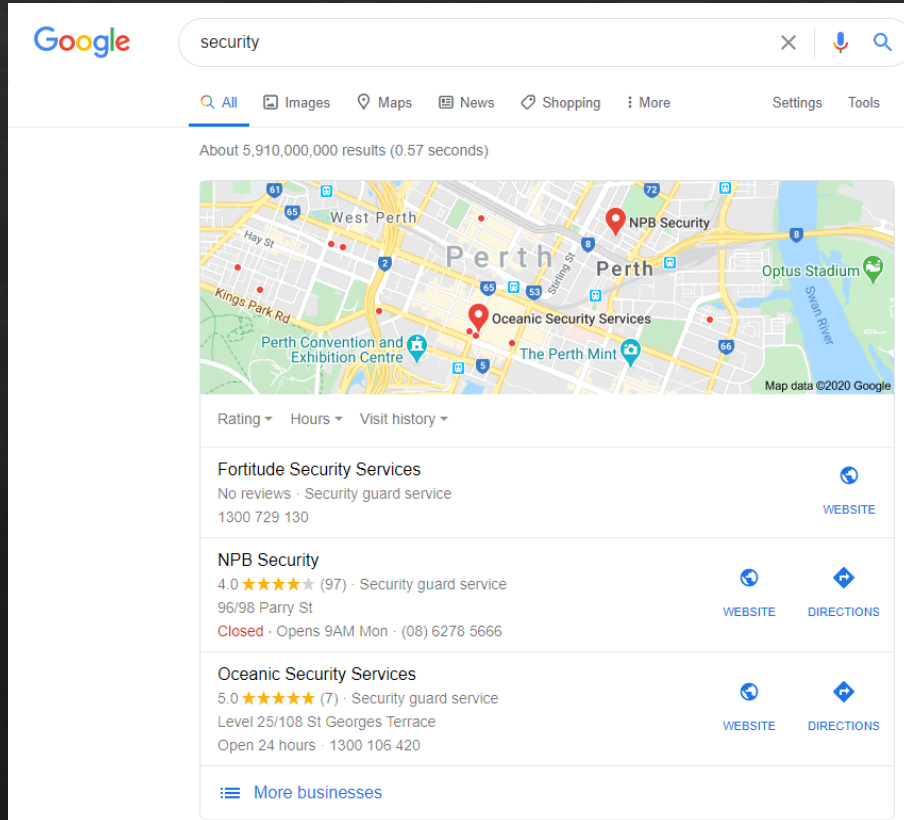
Introduction: outline

- ◇ What is security?
- ◇ Security objectives
- ◇ Defense overview
- ◇ Security management
- ◇ Cybersecurity

Quick stop: Terminology

Term	Meaning
Risk	The potential for an unwanted or adverse outcome resulting from an incident, event, or occurrence, as determined by the likelihood (or the potential) that a particular threat will exploit a particular vulnerability, with the associated consequences.
Vulnerability	A characteristic or specific weakness that renders an organization or asset (such as information or information system) open to exploitation by a given threat or susceptible to a given hazard.
Exploitation	A technique to breach the security of a network or information system in violation of security policy.
Threat	A circumstance or event (including accidental and non-human related) that has or indicates the potential to exploit vulnerabilities and to adversely impact (create adverse consequences for) organizational operations, organizational assets (including information and information systems), individuals, other organizations, or society.
Asset	A person, structure, facility, information, and records, information technology systems and resources, materials, process, relationships, or reputation allowing entities (e.g., individuals, businesses and governments) to achieve social, economic, and other objectives of value .

Security – what is it?



“**Security** is the degree of resistance to, or protection from, harm. It applies to any vulnerable and/or valuable asset, such as a person, dwelling, community, item, nation, or organization.” - Wikipedia

Security – what is it?

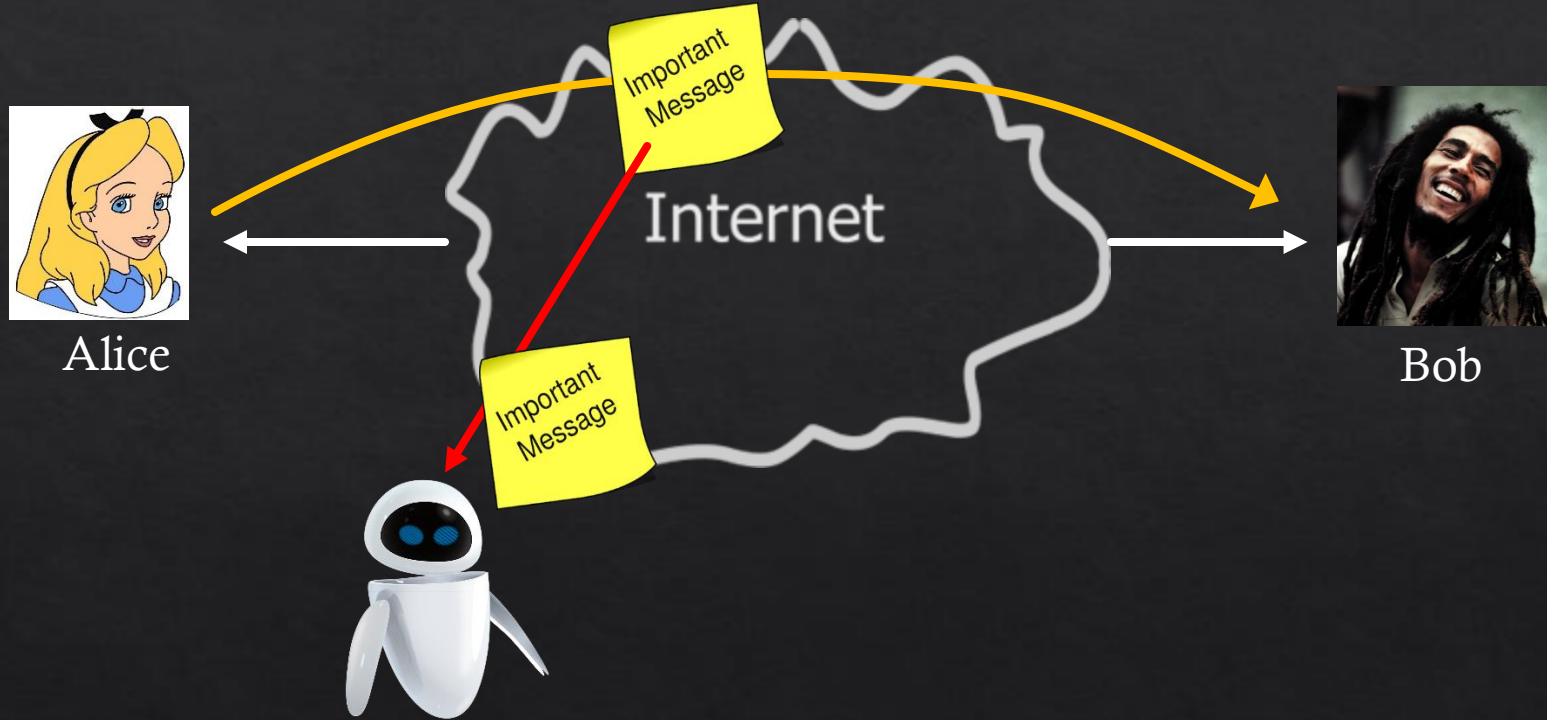
- ◇ The three foundational components in information security
 - ◇ Confidentiality – information is only available to those authorized; e.g., privacy
 - ◇ Integrity – information cannot be modified or damaged by others
 - ◇ Availability – information is always (or to some degree of always) accessible

The CIA Triad

Not this one!



Confidentiality



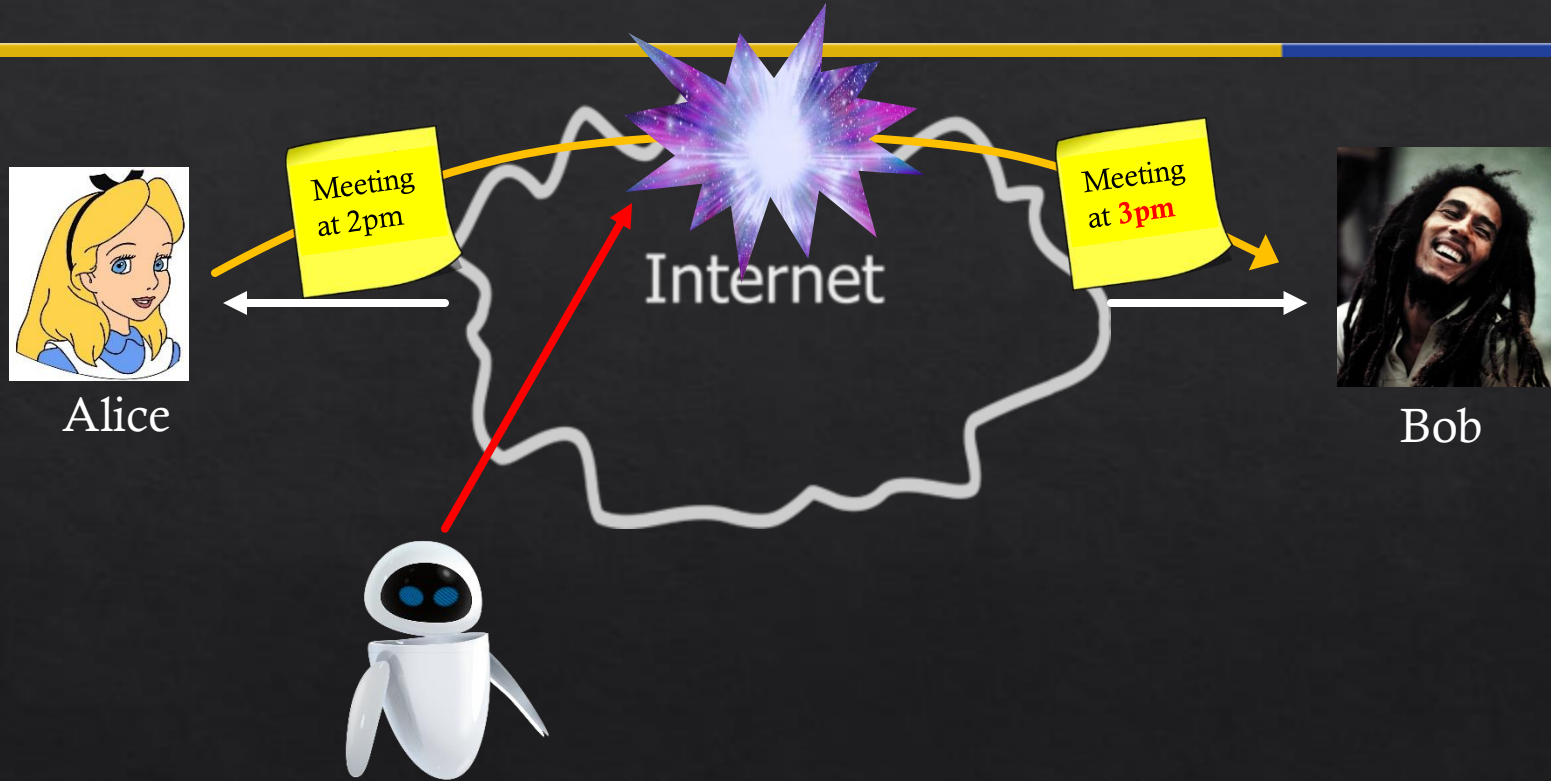
Confidentiality: the information is only accessible by authorised entities.

How to achieve...

◆ Confidentiality?



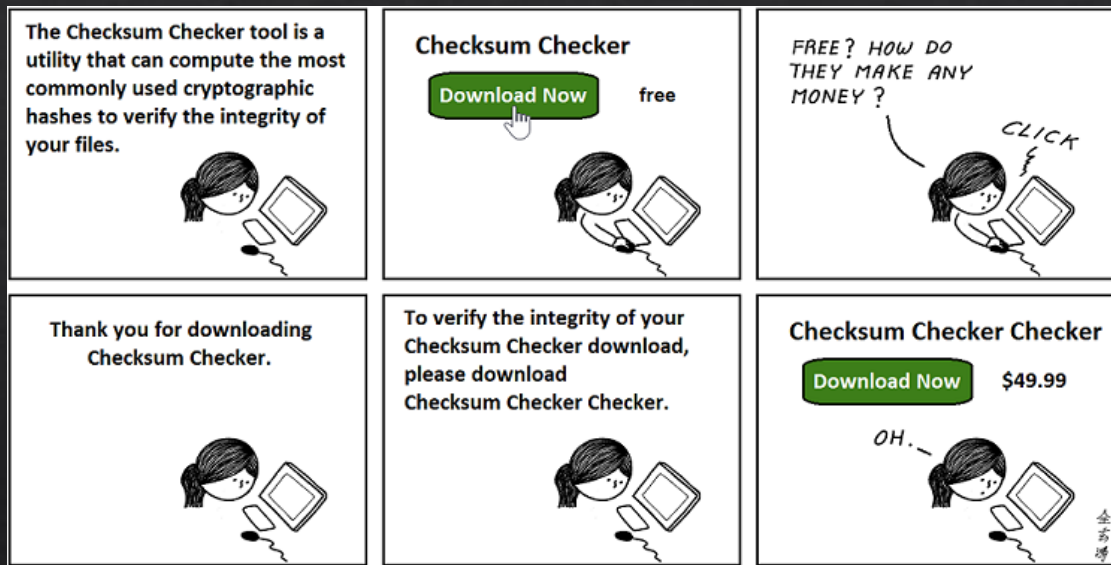
Integrity



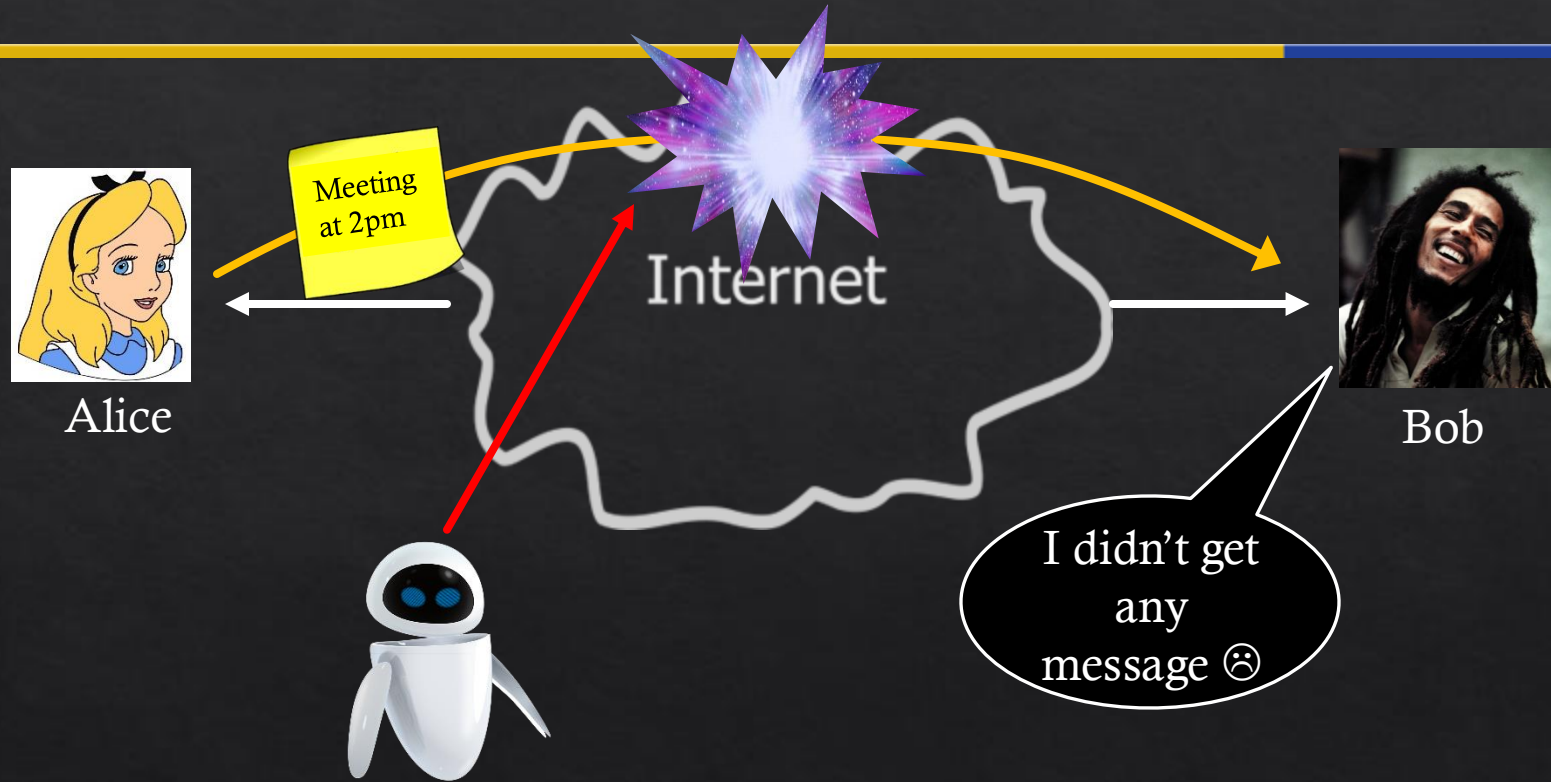
Integrity: the information can only be changed by authorised entities.

How to achieve...

◇ Integrity?



Availability



Availability: the information must be accessible when needed.

How to achieve...

◆ Availability?



Examples

- ◇ In University (in class exercise)
- ◇ In Business
- ◇ In Government

In University

Confidentiality

Integrity

Availability

In Business

Confidentiality

- Project data is undisclosed to the public
- Customer details are encrypted and stored securely

Integrity

- An employee cannot modify his/her own salary
- Annual summary data is not improperly modified

Availability

- Paychecks are received on time as stipulated by law
- Internal network is accessible from the Internet

In Government

Confidentiality

- Passport details are kept safe from public access
- Tax return details are not improperly disclosed to others

Integrity

- Passport details should not be modified by unauthorised persons
- Tax return should be made to the correct bank account

Availability

- Passport details are checked in real time when travelling
- Tax return should be made within 20 working days

Security Objectives summary

◆ Confidentiality

- ◆ To prevent, detect and deter improper disclosure of information

◆ Integrity

- ◆ To prevent, detect and deter improper modification of information

◆ Availability

- ◆ To prevent, detect and deter improper denial of access to services

- ◆ These objectives may have different interpretations in **different contexts**.

But wait, there's more!



Confidentiality



Integrity



Availability



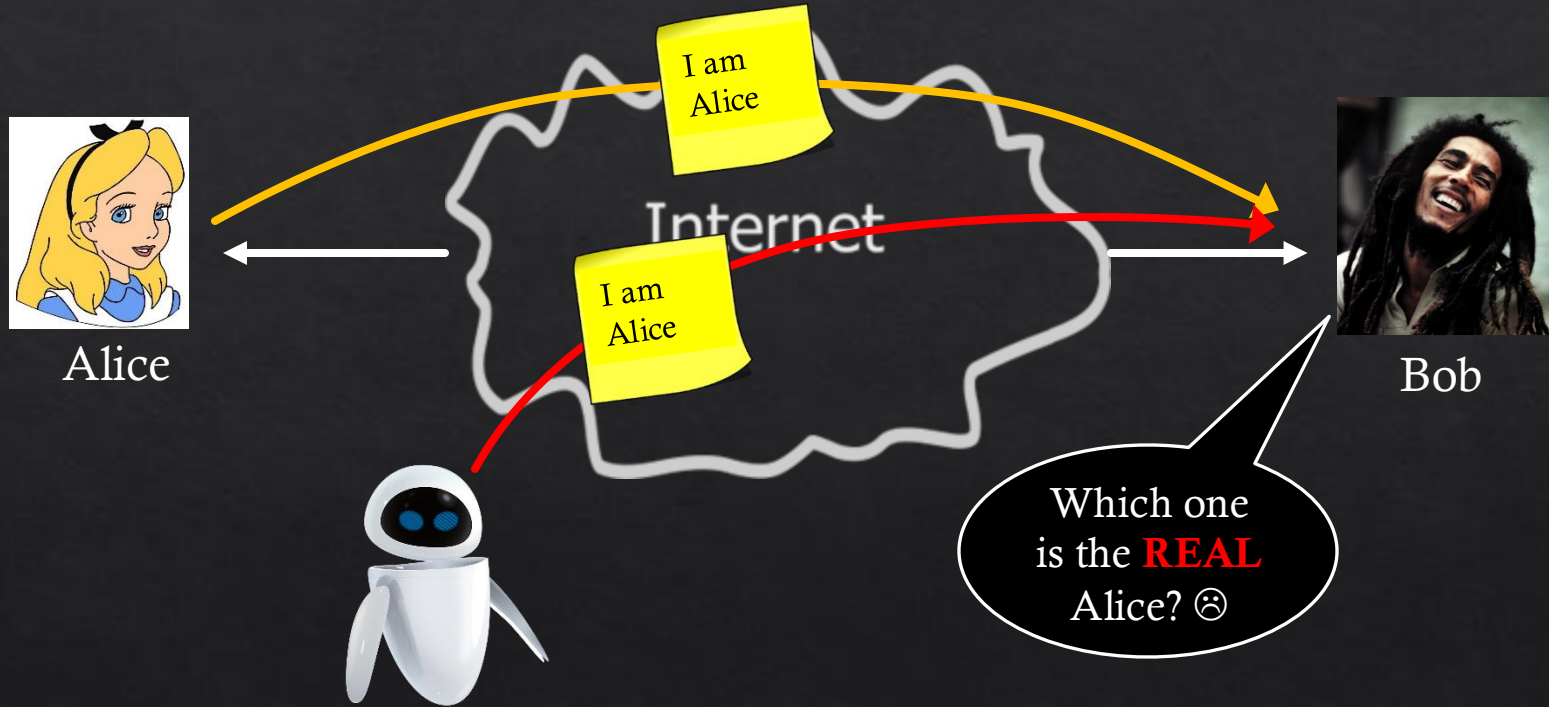
Authentication



Non-repudiation

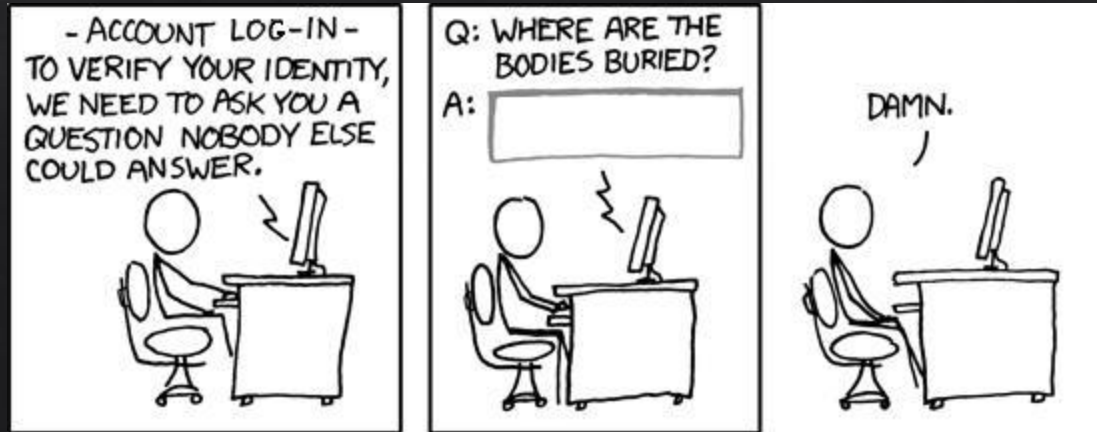


Authentication

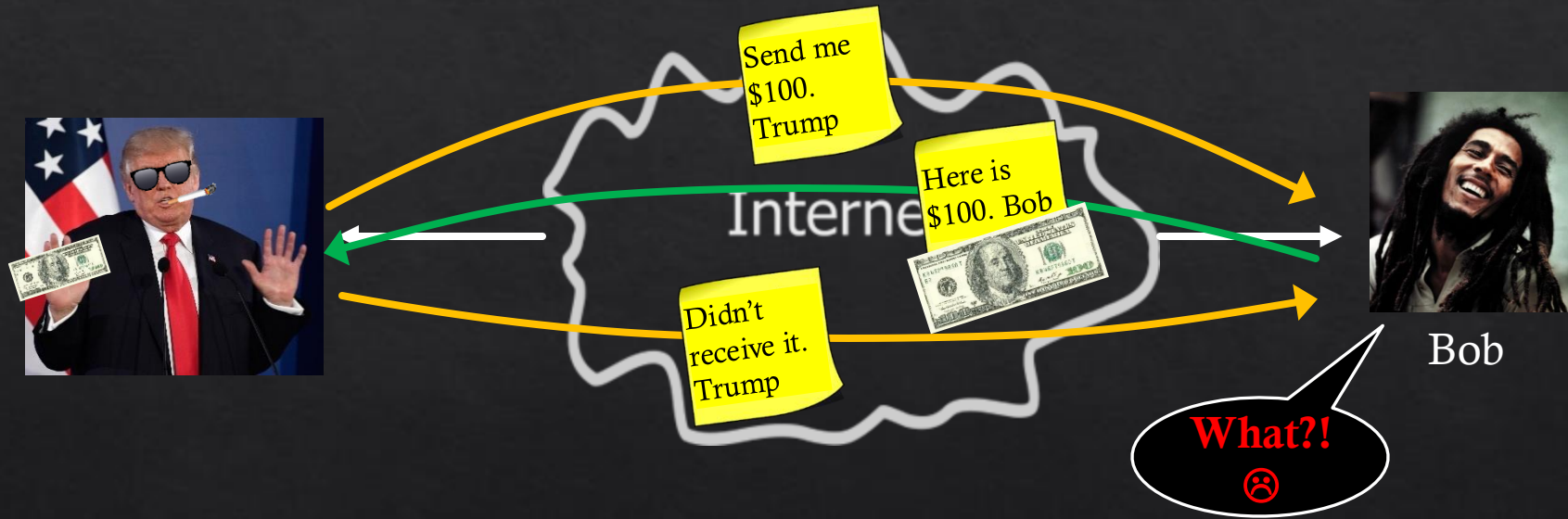


How to achieve...

◇ Authentication?



Non-repudiation



Non-repudiation: entities cannot disclaim their actions.

How to achieve...

◆ Non-repudiation?



“Now we will follow this audit trail and catch him”

Defense overview

- ◆ There are many actions against cyberattacks.

Defense overview

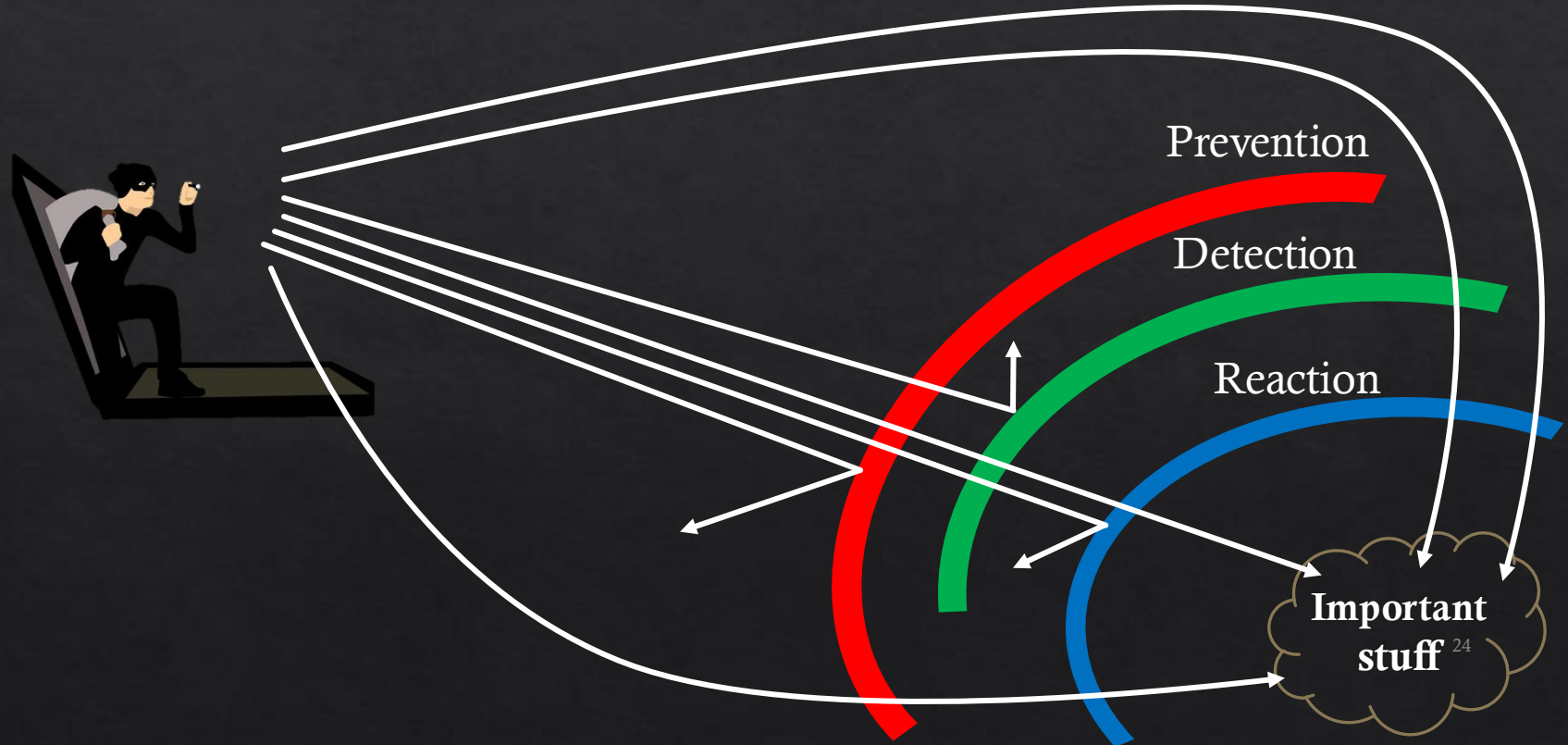
◇ Three types in general.

Prevention Such as:

Detection Such as:

Reaction Such as:

Defense overview



Prevention examples

- ◆ Prevention aims to protect your assets from attacks
 - ◆ Using encryptions for secure communication
 - ◆ Authentication of legitimate users in the system
 - ◆ User information is kept confidential



Detection examples

- ◆ To discover the damage to you asset (what, how, when, who, where).
 - ◆ Unauthorised access attempts in the log
 - ◆ Packet tracing
 - ◆ Intrusion detection systems

2019.04.20.16:27:26-PDF.pcap
osxdaily.com

No.	Source	Destination	Captured Length	Packet Length	Protocol	Data Received	Time Offset	Information
42	253	253	253	253	RadiusTap	2019-04-20 16:27:33.460	18364682	Ver=0, Pmt=0...
43	253	253	253	253	RadiusTap	2019-04-20 16:27:33.881	18368816	Ver=0, Pmt=0...
44	253	253	253	253	RadiusTap	2019-04-20 16:27:33.961	18432096	Ver=0, Pmt=0...
45	253	253	253	253	RadiusTap	2019-04-20 16:27:34.056	18436682	Ver=0, Pmt=0...
46	253	253	253	253	RadiusTap	2019-04-20 16:27:34.056	22460370	Ver=0, Pmt=0...
47	253	253	253	253	RadiusTap	2019-04-20 16:27:34.060	23654000	Ver=0, Pmt=0...
48	253	253	253	253	RadiusTap	2019-04-20 16:27:34.383	23657105	Ver=0, Pmt=0...
49	253	253	253	253	RadiusTap	2019-04-20 16:27:34.691	23660682	Ver=0, Pmt=0...
50	253	253	253	253	RadiusTap	2019-04-20 16:27:34.680	23652660	Ver=0, Pmt=0...

Details

Values

- Date received: 2019-04-20 16:27:33.456 (-0700)
- Time since first packet: 2.340533 seconds
- Packet length: 710 bytes
- Captured length: 710 bytes
- RadiusTap-header: 0
- Version: 0
- Packing: 0
- Length: 25

0000: 00 00 19 00 6f 08 00 00 76 03 9f 58 00 00 00 52 24 79 89 89 84 a0 a1 00 ce 84 72 06 79
0100: 66 8f c4 15 a6 3a 2f a6 76 80 0a c8 f8 89 da 75 59 2f 89 26 68 f0 f3 84 c8 11 52 f2 6c
0200: 20 00 54 14 81 8c 96 69 68 53 81 87 46 87 80 6a ff ff 5c 47 20 f3 2f f3 f8 5c 71 71
0300: 68 89 43 f1 84 89 af 1e f1 fa 29 75 4f 28 f3 0c 19 80 ff 12 80 07 5a 1c 3f 0a f0 74 cf 79
0400: 67 a0 90 81 a3 55 11 51 47 23 4a 40 f1 77 5a 89 10 10 80 56 84 80 58 5f 5f 85 85 84
0500: 45 5c 77 89 f5 48 f2 48 28 c3 9e 5c 49 a5 8e 87 89 84 e2 c3 11 23 2f 4a 44 91 a6 ac 0a f5
0600: 60 83 79 66 08 76 80 50 1a 78 50 10 84 23 52 ac 54 04 c4 72 11 96 7a 81 8f c9 a1
0700: 21 20 64 04 50 1a 84 58 71 f6 81 10 f2 56 83 c3 f6 05 8f 02 70 56 c3 20 70 80 08 00 f6 82
0800: 83 f5 80 00 18 70 2f 10 83 19 66 9c 3f 67 8f 51 84 79 f0 11 71 79 53 99 80 64 a2 0a c9
0900: af 47 45 14 40 11 18 51 13 74 28 46 ac 13 18 38 43 a4 99 68 4c f1 08 20 8c 8c 41 08 2c 97
0a00: c2 af 88 18 18 18 8f 98 c8 ac 89 c3 c2 ff 8c f3 94 54 c9 c8 e8 f4 86 98 e8 a5 98 89 0a aa
0b00: 48 c3 c3 78 18 8c 8c c4 f1 80 8c 8c 59 49 8f 80 c3 9f 56 af 18 3e 57 9c 8f 8a 80 26
0c00: 78 81 cf 07 55 88 6f 2a f6 c4 1c 43 a1 c1 6c 9e 68 58 18 c2 a5 2f fa cf 92 92 18 f2 f8 97

Interpret: 2.4 (Length: 824000 bytes, Linktype: 1073021) RawCap: Filter: 100000 bytes, Packets: 820 of 820 selected

<

DEVICE SECURITY



Threat found

Last scanned: Never

SCAN PHONE

SYSTEM PROTECTION

Unauthorised actions have been detected.
Restart your phone to undo these actions.

RESTART

Reaction examples

- ◇ To enhance security and mitigate attacks.
 - ◇ Deploy two-factor authentication
 - ◇ Revoke malicious membership/access
 - ◇ Enforce deterrence



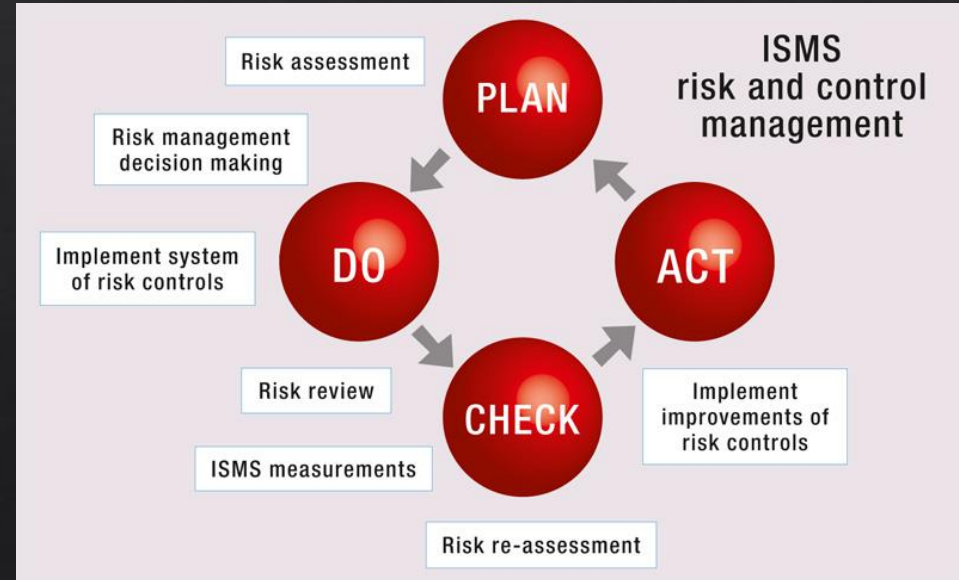
Defense Mechanisms

- ◇ Defense mechanisms includes
 - ◇ Firewall
 - ◇ Vulnerability scanning and patching
 - ◇ IDS and IPS
 - ◇ Security Protocols
 - ◇ IPSec and VPN
 - ◇ Sandboxing
 - ◇ Moving Target Defense
 - ◇ *etc...*

Risk control/management

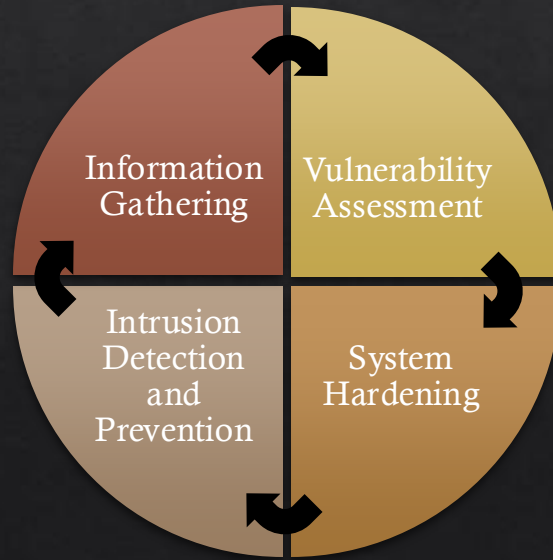
◇ Risk: **unwanted** outcome by a potential **threat**.

◇ Falls under ISO/IEC 27005:2011



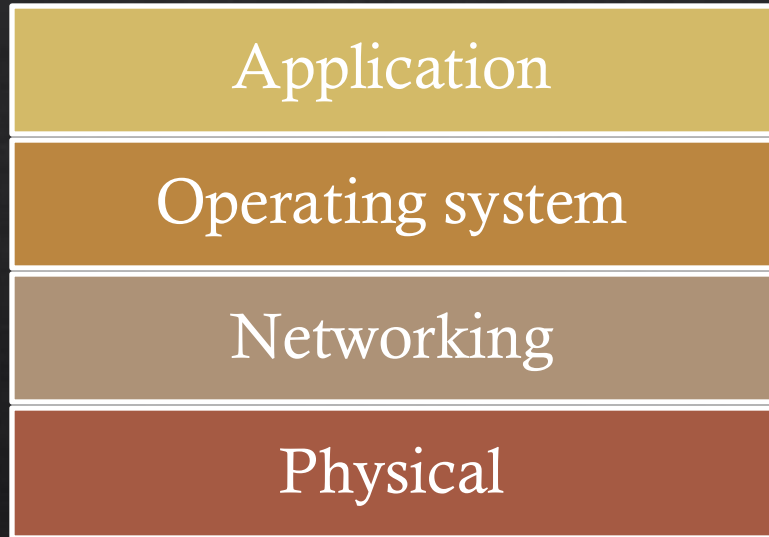
Risk control/management

◇ How to carry out ?



Risk control/management

- ◇ Also think about the layers



Security Policy

- ◇ A set of procedures and tasks to ensure the security objectives of an organisation
 - ◇ Specifies **what** are the assets, and may specify **how** it is done
- ◇ To produce the policy, you need to know
 - ◇ Assets to be protected
 - ◇ E.g., hardware, software, data and information, *anything else?*
 - ◇ Vulnerabilities
 - ◇ Threats
 - ◇ Mitigations

Security Policy

- ◇ Understanding security requirements are critical step towards formulating the security policy
- ◇ Example, passwords
 - ◇ Length
 - ◇ Specification of conditions (e.g., uppercase, special chars)
 - ◇ Frequency of change
 - ◇ Location of the user
 - ◇ Client software specification (e.g., not on mobile)

Security Management

- ◇ Risk control and security policy development is a part of security management.
- ◇ Security management requires security measurements
 - ◇ Quantitative and qualitative
 - ◇ Risk, impact, probability, return on security investment etc.
- ◇ But measurement is a difficult task. Why?

Security Management

- ◇ Security management has a defined standard
 - ◇ ISO/IEC 27001:2013
- ◇ It specifies tasks associated with establishing, implementing, maintaining and continually improving an information security management system.
- ◇ 14 clauses of security controls are defined in this ISO.

Security Management

- ◆ A.5: Information security policies
- ◆ A.6: How information security is organised
- ◆ A.7: Human resources security - controls that are applied before, during, or after employment.
- ◆ A.8: Asset management
- ◆ A.9: Access controls and managing user access
- ◆ A.10: Cryptographic technology
- ◆ A.11: Physical security of the organisation's sites and equipment
- ◆ A.12: Operational security
- ◆ A.13: Secure communications and data transfer
- ◆ A.14: Secure acquisition, development, and support of information systems
- ◆ A.15: Security for suppliers and third parties
- ◆ A.16: Incident management
- ◆ A.17: Business continuity/disaster recovery (to the extent that it affects information security)
- ◆ A.18: Compliance - with internal requirements, such as policies, and with external requirements, such as laws.

Security Management

- ◆ There are other security standards too
 - ◆ U.S. Federal Government information security standards
 - ◆ E.g., NIST SP 800-53
 - ◆ U.S. Department of Defense information security standards
 - ◆ E.g., DoD Instruction 8500.2
- ◆ And other international standards.
 - ◆ Q: Which one should you follow?

Cyber-something

- ◇ Cybersecurity is not only about security mechanisms and methodologies.
- ◇ A broader aspect of the cyberspace safety must be considered.
- ◇ A lot of cyber-something nowadays, let's have a look at a few of interest.

Cyber-something

Cybersecurity

Cyberwarfare

Cyberhacktivism

Cybercrime

Cyberattack

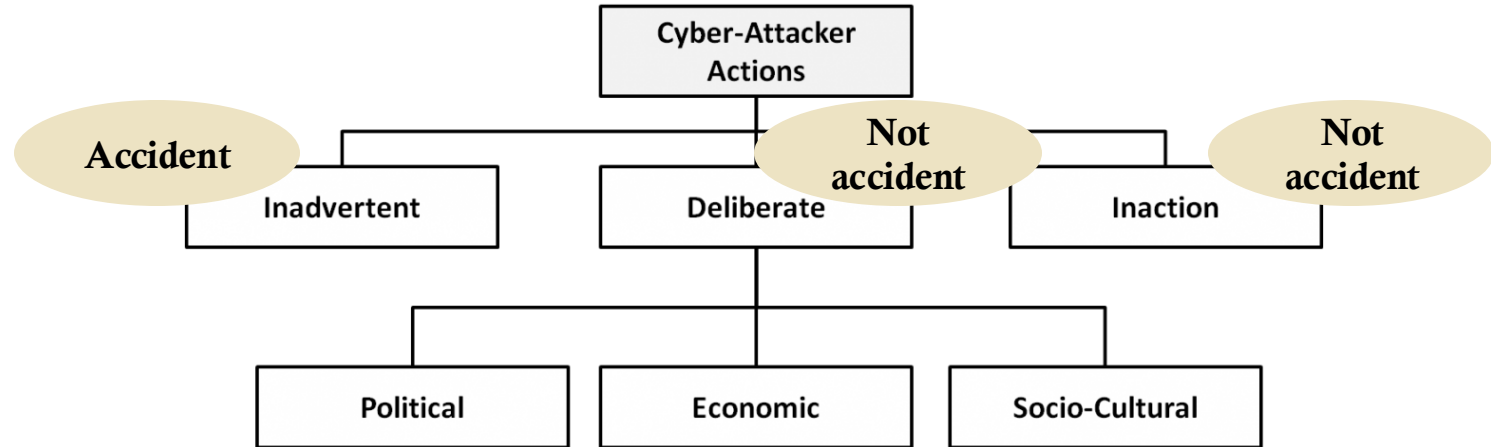
Cybersecurity

“The activity or process, ability or capability, or state whereby information and communications systems and the information contained therein are **protected** from and/or defended against **damage, unauthorized use or modification**, or **exploitation**.” – CNSSI, NIST, DHS and White House

Cyberattack

- ◇ Cyberattack is an act of malicious activities in the cyberspace that causes harm to legitimate entities.
 - ◇ i.e., violating the CIA
- ◇ There are various entities that conduct cyberattacks.
 - ◇ Script kiddies
 - ◇ Black/White Hat Hackers
 - ◇ Hacktivists
 - ◇ Organised criminals
 - ◇ Nation States

Cyberattack



Cybercrime

- ◇ Activities in the cyberspace that violates the laws and regulations.
- ◇ Cybercrimes not only affect financially, but also socially, psychologically and physically.
- ◇ There are laws and regulations to punish cybercrimes.
 - ◇ See the cybercrime details from the Australian Government Attorney-General's Department
 - ◇ <https://www.ag.gov.au/CrimeAndCorruption/Cybercrime/Pages/default.aspx>
- ◇ Still a global issue.

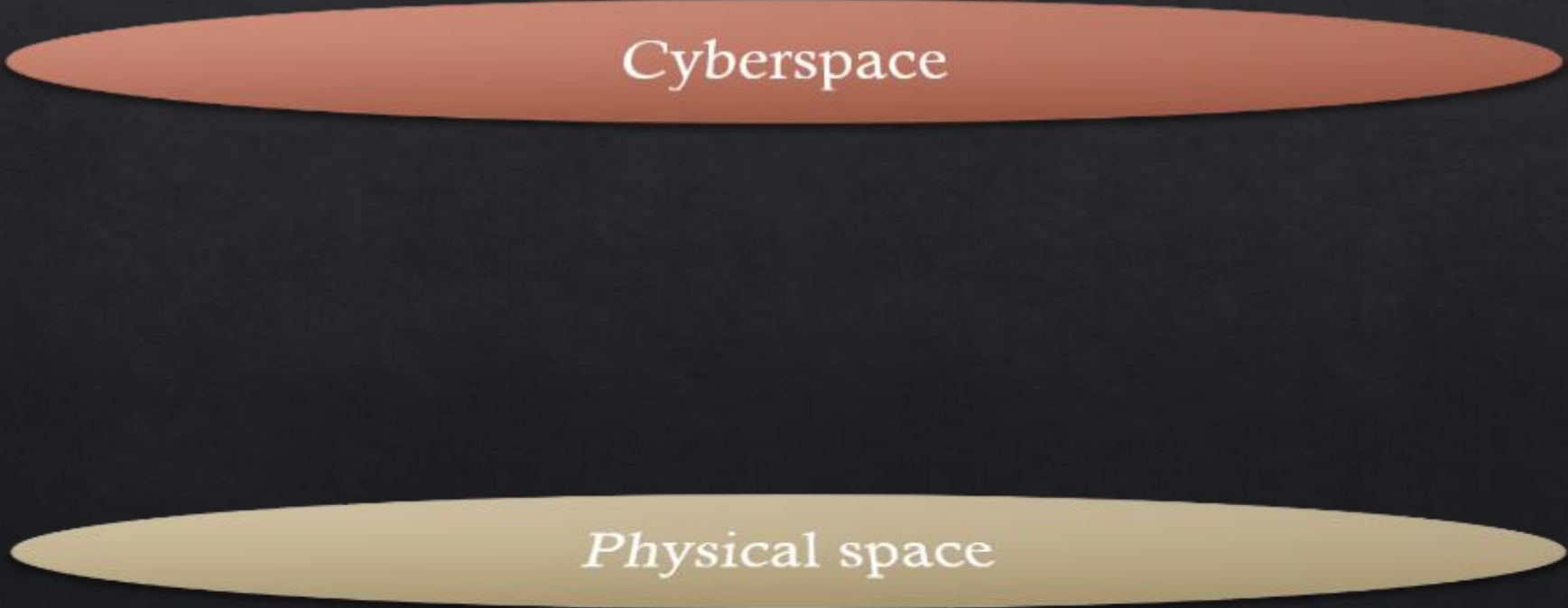
Cyberhacktivism

- ◇ May have other intentions than cybercriminals
 - ◇ i.e., not just personal gains
 - ◇ E.g., Panama papers in 2015
- ◇ Hacktivists pursue:
 - ◇ Political issues
 - ◇ Free speech
 - ◇ Prove a point

Cyberwarfare

- ◆ It's a war!
 - ◆ Involving both attack and defense, but in the cyberspace
- ◆ Involves orchestrated cyberattacks, hacktivism, as well as spies, espionage, sabotage, propaganda and deterrence.
- ◆ No widely accepted rules
 - ◆ Hence the arguments

Importance of cyber



Cyberspace

Physical space

Question

- ◇ Tik Tok collected your private data.
 - ◇ What type of cyberattack is this?
 - ◇ Is this a cybercrime? If yes, what type?
 - ◇ Could it be an unintentional Hacktivism?
 - ◇ Other thoughts?

Additional Items

- ◇ A glossary of cybersecurity terms
 - ◇ <https://niccs.us-cert.gov/glossary>
- ◇ List of ISO standards (like, all of them)
 - ◇ <http://standards.iso.org/ittf/PubliclyAvailableStandards/index.html>

Pre-reading materials

- ◇ Crypto stuff pre-reading/watching:
 - ◇ Youtube video (9 mins): <https://youtu.be/fNC3jCCGJ0o>
 - ◇ Cryptography Introduction (6 mins): <https://www.geeksforgeeks.org/cryptography-introduction/>
 - ◇ Basic Principles (4 mins): <https://www.thegeekstuff.com/2012/07/cryptography-basics>
 - ◇ Intro to public key cryptography (3 mins):
 - ◇ <https://www.globalsign.com/en/ssl-information-center/what-is-public-key-cryptography/>
 - ◇ Intro to RSA (15 mins):
 - ◇ <http://www.dragonwins.com/domains/getteched/crypto/rsa.htm>
 - ◇ Don't have to read thoroughly, just get the idea...